SECURITY

MFA Visual Guide

Multi-Factor Authentication — make a stolen password useless.

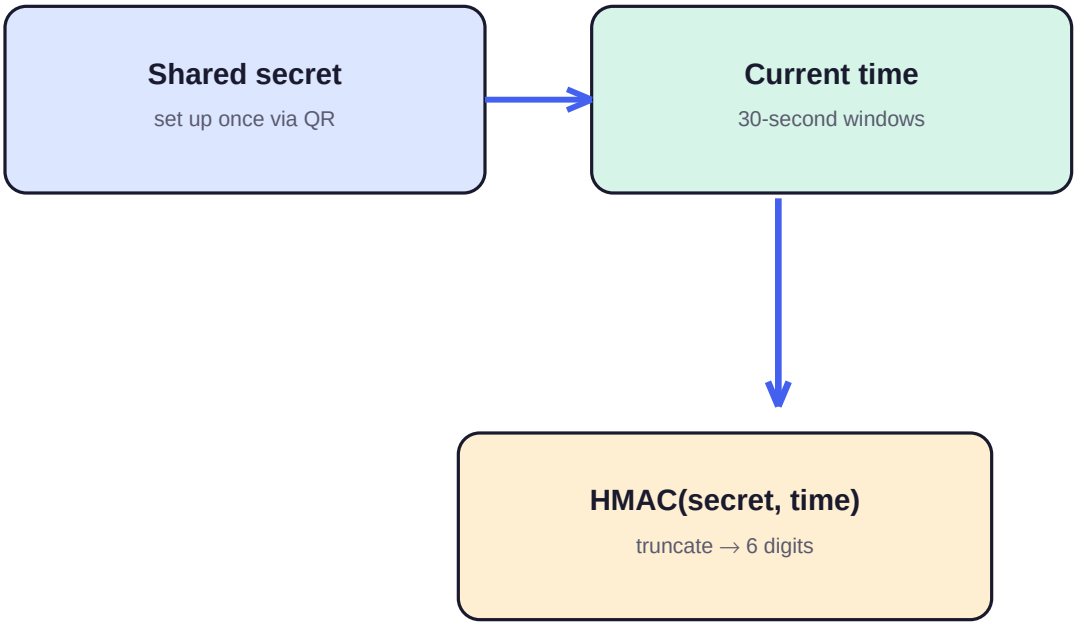
ANIMATED WALKTHROUGH

Step through pages to play the animation

STEP 1/6

TOTP Mechanics

Time-based one-time passwords: shared secret + clock.

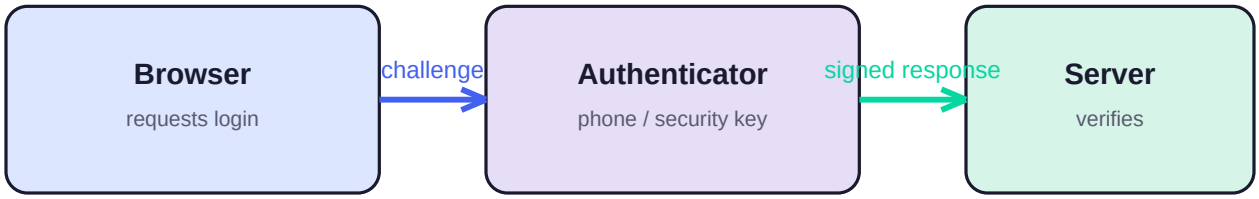


Both sides compute the same code independently — no network needed. Clock drift beyond ~1 window = rejected.

STEP 2/6

WebAuthn / Passkeys

Public-key login bound to the real site.

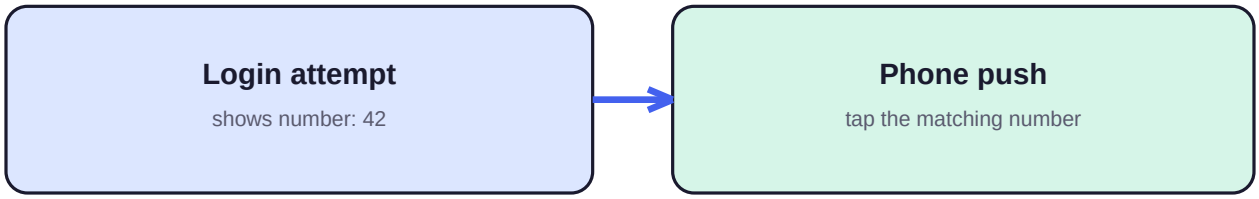


The signature covers the site's origin — a fake site's challenge won't verify. That origin-binding is what defeats phishing.

STEP 3/6

Push Approval & Number Matching

Convenient — but convenience gets attacked.



Number matching defeats 'MFA fatigue' spam-taps. Without it, attackers bombard the user until one tired tap approves.

STEP 4/6

Phishable vs Phishing-Resistant

Not all second factors are equal — rank them.

SMS codes

SIM-swap + interception — weakest, still better than nothing

TOTP / push

Phishable via fake login pages — strong against password theft

WebAuthn / passkeys

Origin-bound cryptography — phishing-resistant

STEP 5/6

Enrollment & Recovery

MFA is only as strong as its reset flow.

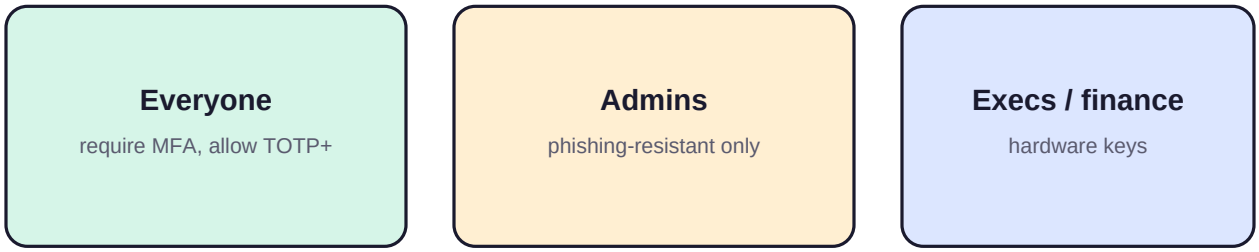
- Enroll MFA at account creation, not as an afterthought.
- Issue backup codes (single-use, stored offline) for lost devices.
- Recovery must re-verify identity as strongly as enrollment — no 'just email me a reset'.
- Log and alert on MFA changes: new device, disabled factor, recovery used.

Most MFA bypasses happen at the help-desk recovery flow, not the crypto. Harden that first.

STEP 6/6

Choosing Your MFA Policy

Match strength to risk.



- Default: phishing-resistant for privileged accounts, TOTP minimum for all.
- Risk-based step-up: challenge again on new device, odd location, sensitive action.

STEP ✓I✓

Key Takeaways

MFA — Remember

- A stolen password alone should never be enough — require a second factor.
- TOTP = shared secret + time, no network needed; keep clocks in sync.
- WebAuthn/passkeys bind the signature to the site's origin — phishing-resistant.
- Use number matching on push; never rely on tired-tap approvals.
- Harden enrollment and recovery — that's where bypasses actually happen.
- Admins and finance get hardware keys; everyone else gets TOTP minimum.

Keep exploring

Pair this guide with the matching video walkthroughs and hands-on labs at interstitiumlabs.dev